

逻辑漏洞之身份认证安全



目录 CONTENTS

01

验证码安全

02

身份认证安全

03

密码找回漏洞

04

用户输入合规性

01

验证安全



验证码原理

验证码 (Captcha) 是一种广泛用于互联网应用程序中的安全机制，旨在验证用户是真实的人类而不是自动化程序或恶意机器人。验证码的原理是通过提出一些对人类容易回答但对计算机难以回答的问题，来阻止自动化攻击和恶意行为。原理如下：

图像识别： 验证码通常以图像或图形的形式呈现给用户，包括数字、字母、特殊字符或图案。用户需要识别并输入验证码中显示的内容。

随机性： 验证码的生成通常具有一定的随机性，以增加攻击者猜测的难度。每个验证码可能会随机选择字符、颜色、字体和位置等属性。

失真和噪声： 为了增加图像识别的难度，验证码图像通常会添加一些失真、扭曲和噪声，使图像更难以被光学字符识别 (OCR) 或自动化脚本识别。

时间限制： 验证码通常有一个时间限制，要求用户在一定时间内完成识别和输入。

 利用场景

1. 登录注册重置密码

2. 活动秒杀

3. 点赞发帖

4. 数据保护:

支付

修改重要账户信息

评论私信留言

验证码漏洞修复方案

1. 增加复杂性

2. 添加噪声和失真

3. 动态验证码

4. 图像反扭曲

5. 多因素身份验证

6. 定期更新设计



图形验证码



验证安全-图形验证码





图形验证码



图形验证码绕过

1. 图形验证码不刷新或无效

2. 验证码复用

3. 存在无验证码页面

4. 万能验证码

5. 验证码数量有限

6. 简单验证码识别

1-1 图形验证码

1. 图形验证码不刷新或无效

网站后台管理系统

用户名：

密 码：

验证码：

8Luq

登 陆

手工尝试一次登录后，在某一时间段内无论登录失败多少次，只要不刷新页面 Session 不过期，就可以无限次的使用同一个验证码来对一个或多个用户帐号进行暴力猜解。

2. 验证码复用

当你打开常见的一些需要登录之类的系统,通常系统会自动请求一次验证码,抓包,抓住别放,保持Session不变。



2. 验证码复用

Target Proxy Spider Scanner Intruder Repeater Sequencer Decoder Comparer Extender Project options User options Alerts Sqlmap SQL注入检测插件

1 x 2 x 3 x 4 x 5 x 6 x 7 x 8 x 9 x 10 x 11 x 12 x 13 x 14 x 15 x 16 x 17 x 18 x 19 x 20 x 21 x 22 x 23 x 24 x 25 x
26 x 27 x 28 x 29 x 30 x 31 x 32 x 33 x 34 x 35 x 36 x 37 x 38 x 39 x 40 x 41 x 42 x 43 x 44 x 45 x 46 x 47 x 48 x 49 x 50 x 51 x 52 x ...

Go Cancel < >

Request

Raw Params Headers Hex

```
POST /index/login/ HTTP/1.1
Host: 
Content-Length: 76
Cache-Control: max-age=0
Origin: http://
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/75.0.3770.100 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3
Referer: http://
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: lang=zh-CN%20ZH%3BQ%3D0.9; PHPSESSID=215242ef40k0hi845o0rrem700
Connection: close

forward=%2F&userName=admin&p=e10adc3949ba59abbe56e057f20f883e&checkCode=j5mj
```

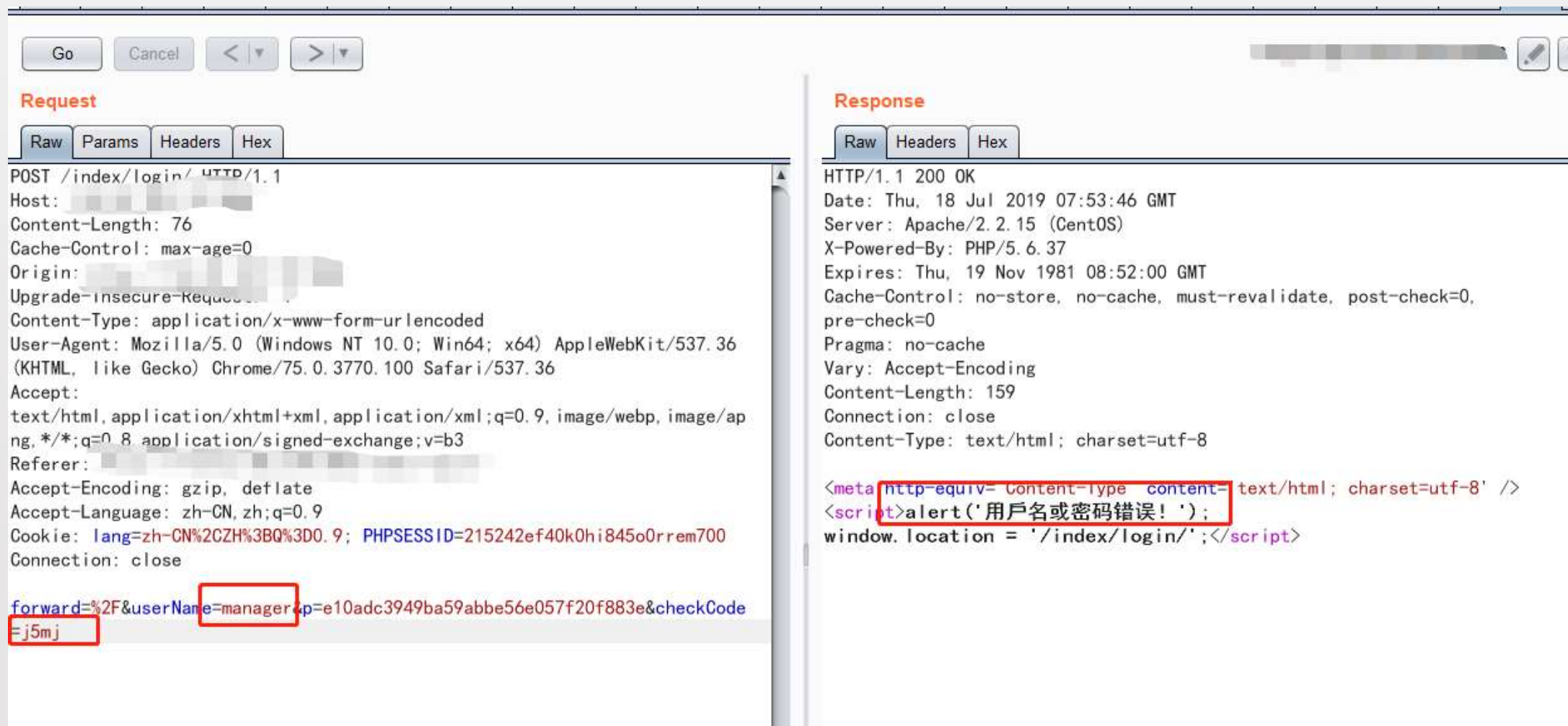
Response

Raw Headers Hex

```
HTTP/1.1 200 OK
Date: Thu, 18 Jul 2019 07:53:46 GMT
Server: Apache/2.2.15 (CentOS)
X-Powered-By: PHP/5.6.37
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 159
Connection: close
Content-Type: text/html; charset=utf-8

<meta http-equiv='Content-Type' content='text/html; charset=utf-8' />
<script>alert('用户名或密码错误!');
window.location = /index/login/;</script>
```

2. 验证码复用



Request

Raw Params Headers Hex

```
POST /index/login/ HTTP/1.1
Host: 
Content-Length: 76
Cache-Control: max-age=0
Origin: 
Upgrade-Insecure-Requests: 
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/75.0.3770.100 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3
Referer: 
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: lang=zh-CN%2CZH%3BQ%3D0.9; PHPSESSID=215242ef40k0hi845o0rrem700
Connection: close

forward=%2F&userName=manager&password=e10adc3949ba59abbe56e057f20f883e&checkCode=j5mj
```

Response

Raw Headers Hex

```
HTTP/1.1 200 OK
Date: Thu, 18 Jul 2019 07:53:46 GMT
Server: Apache/2.2.15 (CentOS)
X-Powered-By: PHP/5.6.37
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 159
Connection: close
Content-Type: text/html; charset=utf-8

<meta http-equiv= Content-type content= text/html; charset=utf-8' />
<script>alert('用户名或密码错误!');
window.location = '/index/login/';</script>
```

2. 验证码复用

Intruder attack 32

Attack Save Columns

Results Target Positions Payloads Options

Filter: Showing all items

Request	Payload	Status	Error	Timeout	Length	Comment
0		200	☐	☐	513	
4	1	200	☐	☐	513	
6	11111111	200	☐	☐	513	
7	2	200	☐	☐	513	
8	22222222	200	☐	☐	513	
9	30	200	☐	☐	513	
10	4Dgifts	200	☐	☐	513	
11	5	200	☐	☐	513	
12	7	200	☐	☐	513	
13	ADAMS	200	☐	☐	513	

Request Response

Raw Headers Hex

```
HTTP/1.1 200 OK
Date: Thu, 18 Jul 2019 08:12:11 GMT
Server: Apache/2.2.15 (CentOS)
X-Powered-By: PHP/5.6.37
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 159
Connection: close
Content-Type: text/html; charset=utf-8

<meta http-equiv='Content-Type' content='text/html; charset=utf-8' />
<script>alert('用户名或密码错误!');
window.location = '/index/login/';</script>
```

162 of 8894

3. 存在无验证码页面

经过测试，如果我们发现网站验证码自身并不存在缺陷，那我们接下来就可以尝试寻找一些其他的登录页面或接口来尝试暴力破解。如隐藏的页面、测试页面、老旧版本的页面等。

查看源代码，发下如下接口无需验证码，可用来爆破：

```
{
  'type' : 'POST',
  //如果默认密码强制跳转到密码修改页面，请调用【ws/loginToRedirectUri】服务（需要c2-sysmgr-api至1.0.7+或者升级系统管理到4.2.2+）
  'url' : 'http://[redacted]ws/captchaLogin',
  'data' : JSON.stringify({
    'userName' : $('#username').val(),
    'password' : $('#password').val(),
    'captcha' : $('#captcha').val(),
    'type' : status
  }),
  'dataType' : 'json',
  'success' : function(data, type, request) {
    if (request.getResponseHeader('type') === 'error') {
      if (request.getResponseHeader('isShowMessage') === 'true') {
        var message = request.getResponseHeader('message') ? decodeURI(request.getResponseHeader('message')) : "登录异常，请联系管理员！";
        showMessage(message);
        status = "1"; // 输入密码错误，需要开启验证码验证！
        $('#captchaHide').show();
        refreshImg();
      } else {
        showMessage("登录异常，请联系管理员！");
      }
      $('#username').focus().select();
    } else {
      // 后台重定向，调用ws/loginToRedirectUri服务时添加这段代码
      var redirectUri = data.redirectUri;
      if (null != redirectUri) {
        location.href = redirectUri;
        return;
      }
    }
  }
}
```

4. 万能验证码

渗透测试的过程中，有时候会出现这种情况，系统存在一个万能验证码，如0000、9999，只要输入万能验证码，就可以无视验证码进行暴力破解。



5.验证码数量有限

多见于计算类型的验证码，如 $1+2=?$ ，这种类型的验证码严格意义上来说不能叫做验证码，多刷新几次验证码，我们可能会发现系统中的算数题目只有那么几道，这种情况下只要将验证码全部下载下来，生成一个 md5 库，然后将前端生成的验证码与本地文件进行对比即可。

1-1 图形验证码

6.简单验证码识别

在平常的漏洞挖掘过程中，如果我们发现登录的验证码非常简单且易于识别，那我们就可以尝试使用自动化工具来进行登录破解了，如 PKAV 的 HTTP Fuzzer、bp插件等。

http://172.16.8.95/xx/admin/index.php?c=login

UTF-8

username=\${USER}&password=\${MD5_16(MD5_16(PASS)+UPPER(VER))}&code=\${VER}&submit=登录

http://172.16.8.95/xx/index.php?c=api&a=checkcode&width=85&height=26

☒ 使用验证码

d:\Users\Nemo\Desktop\New folder\New folder\TEST.ci.png

打开

验证码不正确

账户或密码不正确

当页面出现此匹配时更换代理(正则)

☐ 使用代理

导入代理

.....

导入用户

2个

导入密码

4个

{DL}

{DM}

{DR}

使用说明

超时时间:

5000

线程: 10

构造测试

开始

用户名	密码	状态码	页面长度	备注
admin	111111	200	689	密码错误
test	admin	200	689	密码错误
admin	admin	200	689	密码错误
admin	a123456	200	570	未知结果
admin	testtest	200	689	密码错误
test	a123456	200	689	密码错误
test	testtest	200	689	密码错误
test	111111	200	689	密码错误

http://172.16.8.95/xx/admin/index.php?c=login->username=test&password=ac80d5aeefc41e42&code=2EEE&submit=登录

Proxy:null

21/2/2016 22:14:18--test--111111--

http://172.16.8.95/xx/admin/index.php?c=login->username=test&password=3e66a4fa3901436d&code=ZAAU&submit=登录

Proxy:null

https://blog.csdn.net/weixin_40412037/article/details/105561166

1-2

短信验证码



短信验证码绕过

- 1.短信验证码生命期限内可暴力枚举
- 2.短信验证码在数据包中返回
- 3.修改请求数据包参数或 Cookie 值绕过
- 4.修改返回包绕过
- 5.攻破短信验证码接口
- 6.默认万能验证码
- 7.验证码无校验

1-2 短信验证码

1. 短信验证码在生命期限内可以暴力枚举

图片验证码无效，此接口 4 位手机验证码可爆破：

Filter: Showing all items

Request	Payload	Status	Error	Timeout	Length	15\r\n\r\n\xef\xbb\...	Comment
122	3521	200	☐	☐	448	"status":1	
0		200	☐	☐	448	"status":2	baseline request
1	3400	200	☐	☐	448	"status":2	
2	3401	200	☐	☐	448	"status":2	
3	3402	200	☐	☐	448	"status":2	
4	3403	200	☐	☐	448	"status":2	
5	3404	200	☐	☐	448	"status":2	
7	3406	200	☐	☐	448	"status":2	
8	3407	200	☐	☐	448	"status":2	
9	3408	200	☐	☐	448	"status":2	

Request Response

Raw Params Headers Hex

POST /Member/common/resetPwd/ HTTP/1.1

Host: [REDACTED]

Connection: close

Content-Length: 43

Accept: application/json, text/javascript, */*; q=0.01

Origin: [REDACTED]

X-Requested-With: XMLHttpRequest

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/63.0.3239.108 Safari/537.36

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN, zh;q=0.9

[REDACTED]

pass=ab[REDACTED]&uphone=130[REDACTED]3&pcode=1234

爆破正确的手机验证码为3521，
密码修改成功

1-2 短信验证码

2.短信验证码在数据包中返回

可以直接在response中获取到短信验证码。



验证码是327129，该验证码有效时间10分钟，请您及时输入。(来自...)

1-2 短信验证码

2.短信验证码在数据包中返回

选房、购房、买卖房、装修房、
统统“一号搞定”!

输入任意手机号

口袋乐居

抢工长

二手网

新屋二手房

短信快捷登录

账号登录

点击获取动态密

13333333333

动态密码

获取动态密码

登录

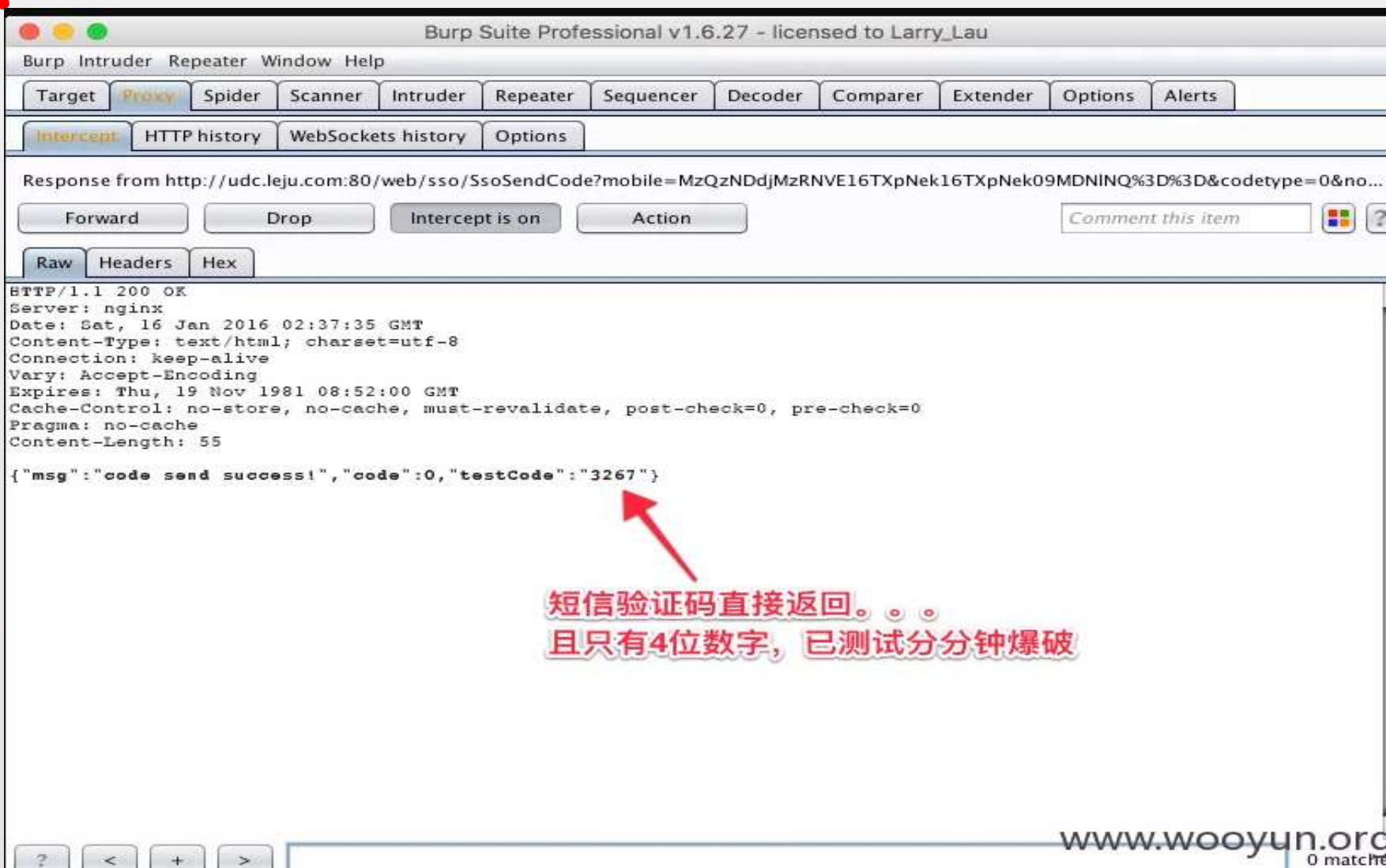
验证即登录，未注册将自动创建乐居通行证帐号

你也可以用以下方式登录：



1-2 短信验证码

2.短信验证码在数据包中返回



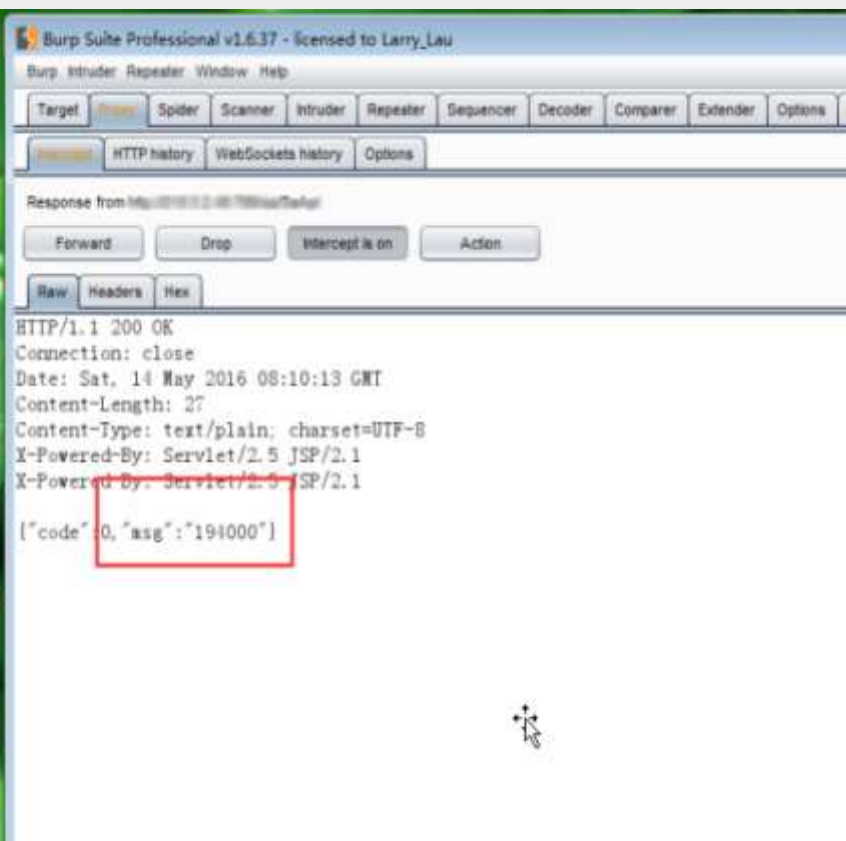
1-2 短信验证码

2.短信验证码在数据包中返回



1-2 短信验证码

2.短信验证码在数据包中返回



1-2 短信验证码

2.短信验证码在数据包中返回



A mobile app interface for entering a verification code. It features a blue header with a back arrow, a blurred profile picture, and a home icon. Below the header, there are four input fields: the first contains the phone number '18888888888', the second contains '194000' with a '166s' timer, the third and fourth are masked with dots. A blue '确定' (Confirm) button is at the bottom.



A mobile app interface showing a user profile and a menu. The top blue header displays a profile picture, the phone number '手机号码:18888888888', the nickname '昵称:测试', and a right arrow. Below the header, there are two status bars: '未认证' (Not authenticated) with a person icon and '未绑定网报' (Not bound to network report) with a person icon. The main area contains a list of menu items with icons and right arrows: '抽奖记录' (Drawing record), '中奖情况' (Winning situation), '咨询问题' (Consultation questions), '我的收藏' (My favorites), and '设置' (Settings).

3.修改请求数据包参数或cookie值绕过

比如有 post 数据包: `mobile=18888888888&userid=00001`, Cookie中有:
`codetype=1`

在特定步骤, 修改 `mobile`=自己的手机号, 自己手机就可以收到别人的验证码, 后面再用别人的手机号和接收到的验证码登录;

修改 Cookie 中可疑的参数和值, 进行绕过, 比如上面修改 `codetype=0`;

4.修改返回包绕过

举个简单的例子：提交错误的短信验证码，返回包中有： status=false，用 Burpsuite 的 "Do intercept" 功能修改为 status=true，即可绕过前端判断，成功进入系统。具体还要结合实际的场景，灵活操作。

发送验证码以后，随便输入一个验证码，然后抓包，截断，修改response：

```
POST [redacted] /tnp/app/member/extension/checkSMSCode HTTP/1.1
sid: 243c9892-d530-49a3-b02d-890a88808282
User-Agent: BFApp/1.2.0/Dalvik/1.6.0 (Linux; U; Android 4.4.2; PE-TL10 Build/HuaweiPE-TL10)
sessionid:
host: [redacted]
Content-Type: application/json; charset=UTF-8
Content-Length: 689
Connection: Keep-Alive
Accept-Encoding: gzip
```

false改成true

修改此接口的response为：

`{"errorCode":0,"success":true}`

即可绕过短信验证码，下一步直接修改密码。

1-2 短信验证码

5.攻破短信验证码接口

- 1、有些网站会遗留短信验证码测试页面，比如/smstest.html等，如果能找到并且还可以正常使用。
- 2、一般系统的短信验证码功能，都会有个接口平台可以获取到手机接收到的所有短信，找到并攻破也能进入系统。

SMS短信管理系统登陆

用户名: 密 码: 验证码: 

LOGIN
登 陆

SMS短信运营平台 Operation Platform

用户名:

密 码:

登 录 取 消

6. 万能短信验证码

之前遇到过短信验证码输入9999，就可以登录任意用户账号的漏洞。

为了方便测试以及维护，有的系统会留有万能验证码，上线后还保留着。可能是固定的写在配置文件、js文件或代码中，也可能是随时间变化的。



The image shows a registration form with the following elements:

- A blue "注册" (Register) link at the top.
- A phone number input field with a dropdown menu showing "+86(CN)" and a placeholder "请输入手机号".
- A captcha input field with a placeholder "请输入验证码" and a blue "获取验证码" (Get Captcha) button.
- A password input field with a placeholder "请输入密码".
- A confirmation password input field with a placeholder "请确认密码".
- A checkbox labeled "我已经阅读并接受" (I have read and accept) followed by a blue link "用户协议" (User Agreement).
- A large blue "注册" (Register) button.
- A link "已有账号? 去登录" (Already have an account? Go to login) at the bottom.

1-2 短信验证码

6. 万能短信验证码

注册成功

注册

+86(CN) 13388889999

000000 [获取验证码](#)

•••••

•••••

☒ 我已经阅读并接受 [用户协议](#)

[注册](#)

[已有账号? 去登录](#)

基本信息

用户名 [gj_356582954](#) [头像](#) [主账号](#)

真实姓名 超级管理员

角色 平台管理员

手机号码 13388889999 [更改](#)

邮件账号 -

密码 [更改](#)

绑定微信 

6. 万能短信验证码

之前遇到过短信验证码输入9999，就可以登录任意用户账号的漏洞。

为了方便测试以及维护，有的系统会留有万能验证码，上线后还保留着。可能是固定的写在配置文件、js文件或代码中，也可能是随时间变化的。

1-2 短信验证码

7. 短信验证码无校验

任意密码重置，随意输入验证码就可以修改别人用户的密码，就直接得到了其他用户的账号，危害十分巨大



修改密码

手机号: 13333333333

验证码: 123456 47秒后可再次发送

新密码:

确认新密码:

确定 取消



登录 注册

账号: admin

密码: 忘记密码?

登录

02

身份认证安全



身份认证安全原理

身份认证是应用程序和系统中的关键组成部分，用于验证用户是否有权访问其帐户或执行特定操作。

绕过测试：

1. 暴力破解
2. session & cookie类
3. 弱加密

利用场景

1. 用户登录
2. 多因素身份验证
3. 社交媒体登录
4. 密码重置
5. API身份认证
6. SSO单一登录
7. 电子商务支付
8. 云服务和存储

1.暴力破解

在没有验证码限制或者一次验证码可以多次使用的地方，使用已知用户对密码进行暴力破解或者用一个通用密码对用户进行暴力破解。简单的验证码爆破。

一些工具及脚本：
Burpsuite

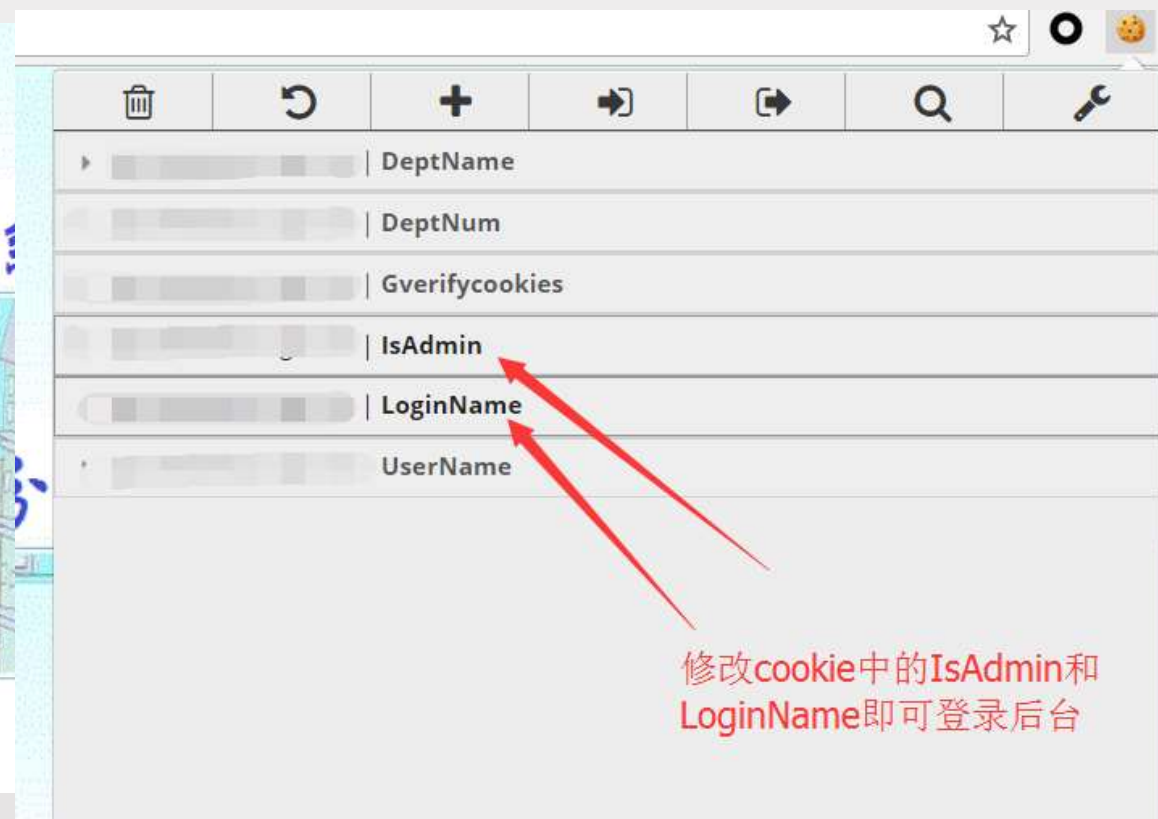
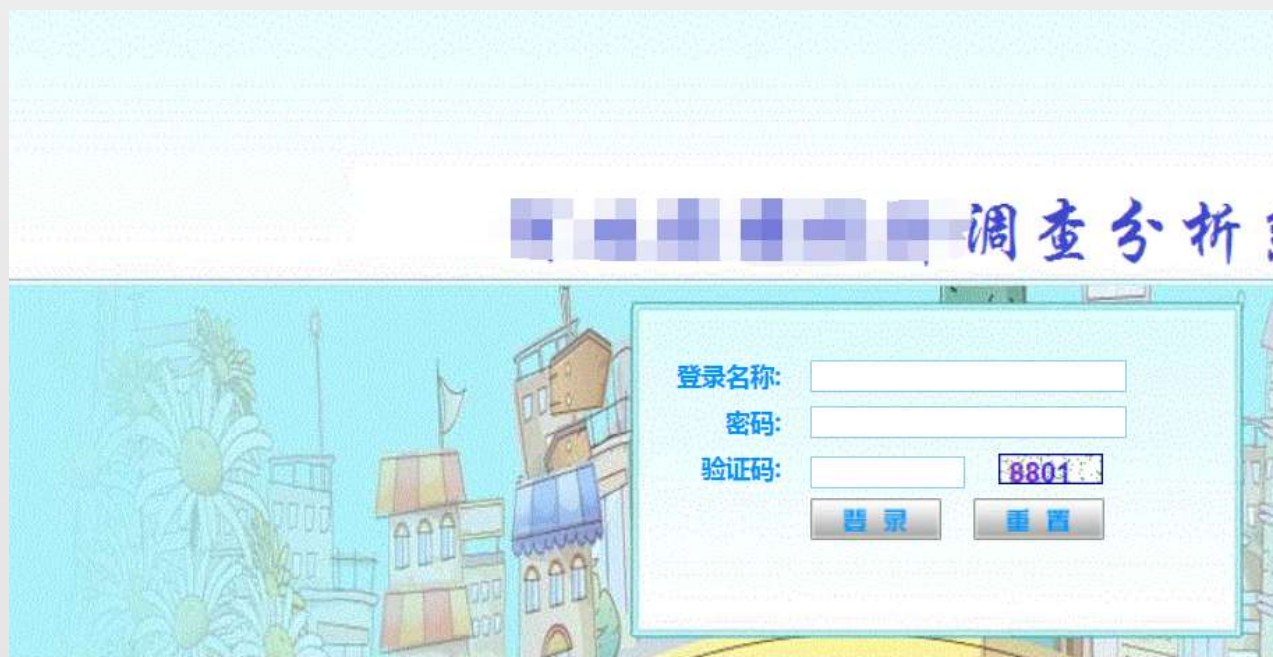
htpwdScan 撞库爆破必备 URL: <https://github.com/lijiejie/htpwdScan>

hydra 源码安装xhydra支持更多的协议去爆破 (可破WEB，其他协议不属于业务安全的范畴)

2.session & cookie类

会话固定攻击：利用服务器的session不变机制，借他人之手获得认证和授权，冒充他人。

Cookie仿冒：修改cookie中的某个参数可以登录其他用户（Chrome插件：EditThisCookie）。



03 身份认证安全

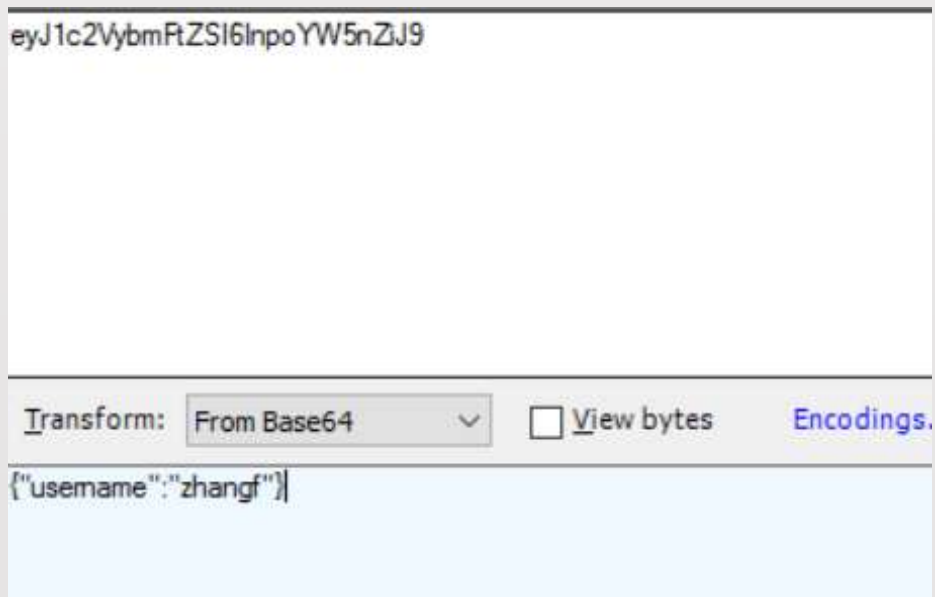
3.弱加密

前端加密，可破解，或者根本就不是加密。

比如如下案例，找回密码，得到一个token：

`/resetpwd?token=eyJ1c2VybmFtZSI6InpoYW5nZiJ9`

Token实际上就是将username编码了一下，修改username即可修改其他用户的密码



防御方式

1. 多因素认证
2. 密码策略
3. 防止暴力破解
4. 单点登录 (SSO)
5. 安全问题和答案
6. 弱密码检测

03

密码找回



密码找回漏洞

密码找回逻辑测试一般流程

1. 首先尝试正常密码找回流程，选择不同找回方式，记录所有数据包
2. 分析数据包，找到敏感部分
3. 分析后台找回机制所采用的验证手段
4. 修改数据包验证推测

密码找回漏洞

- 1、验证码暴力破解
- 2、验证码直接返回
- 3、跳过验证步骤
- 4、利用邮箱、手机号绑定
- 5、第三方登录绑定其他用户
- 6、没有验证验证码接受手机号是否与username或者session一致

 密码找回漏洞

- 7、本地验证绕过
- 8、重置密码最后一步uid或者username可控
- 9、个人中心修改密码逻辑错误
- 10、利用session重新绑定用户
- 11、去掉验证参数绕过验证
- 12、任意输入验证码修改用户密码

1. 验证码暴力破解

手机或者邮箱验证码可枚举破解

第一步，点击忘记密码，会要求输入注册邮箱，输入点击找回密码会收到一份邮件

亲爱的[REDACTED]：

您好！您在2013年07月17日 03时22分08秒（修改密码请求提交的详细时间）提交了找回密码请求，请点击下面的链接设置新密码：

[http://www.codoon.com/verify_email?email=\[REDACTED\]05@qq.com&code=2208](http://www.codoon.com/verify_email?email=[REDACTED]05@qq.com&code=2208)

为保障您帐号的安全性，该链接24小时内有效，并且在您使用一次后自动失效！

感谢您的使用！

www.wooyun.org

可以看到找回密码url是主要由邮箱和4位数字验证码构造而成，而且24小时有效。

下面用burpsuite访问抓包 intruder之！

03 密码找回漏洞

1. 验证码暴力破解

```
    "appName" : "11",  
    "appChannel" : "android",  
    "currentNum" : "11",  
    "dentifyingCode" : "1111",  
    "imeiCode" : "WkMzSmh3TnVtWjREQU90RjdjanZhQON0",  
    "pageEnd" : "11",  
    "pageStart" : "11",  
    "partyId" : "",  
    "password" : "xc191015",  
    "pgupdownFlag" : "11",  
    "phoneNumber" : "19108465890",  
    "token" : "",  
    "totalNum" : "11",  
    "userLoginId" : "",  
    "versionStatus" : "1"  
}
```

验证码

要修改的密码

修改密码的对象

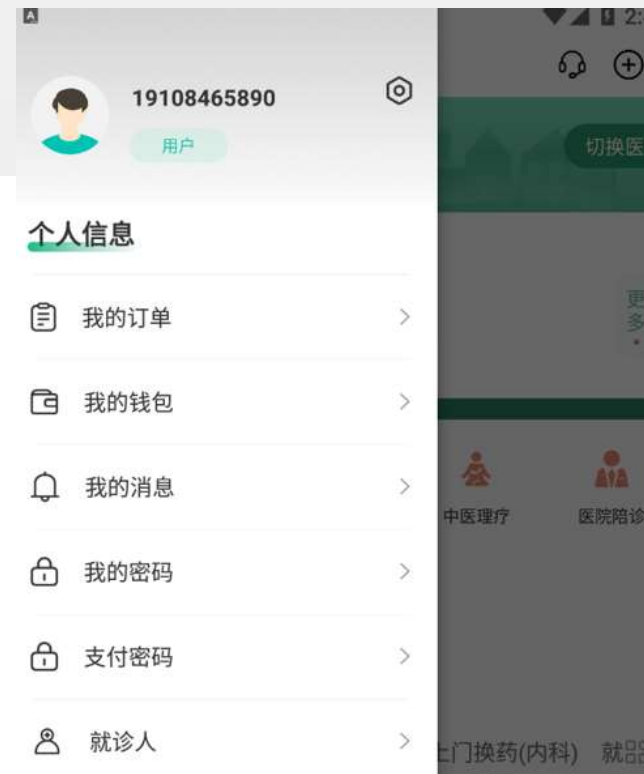
Filter: Showing all items						
Request	Payload	Status	Error	Timeout	Length ^	Comment
3716	3715	200	☐	☐	727	
0		200	☐	☐	741	
1	0000	200	☐	☐	741	
2	0001	200	☐	☐	741	
3	0002	200	☐	☐	741	
4	0003	200	☐	☐	741	

1. 验证码暴力破解

重发一次，提示success

```
"KeyId": "11",
"LegalRepCode": "A999999",
"LocalLang": "11",
"Mac": "11",
"RetMsg": "11",
"ServiceCode": "11",
"ServiceName": "11",
"SourceSysId": "11",
"TerminalCode": "11",
"TranCode": "11",
"TranDate": "11",
"TranSeq": "11",
"TranTeller": "11",
"TranTime": "11",
"appChannel": "android",
"currentNum": "11",
"identifyingCode": "3715",
"imeiCode": "WkMzSmh3TnVtWjREQU90RjdjanZhQON0",
"pageEnd": "11",
"pageStart": "11",
"partyId": "",
"password": "xc191015",
"pgupdownFlag": "11",
"phoneNumber": "19108465890",
"token": ""
```

```
11 {
12   "desc": "success",
    "status": "000",
    "SourceSysId": "11",
    "ConsumerId": "11",
    "ServiceCode": "11",
    "GlobalSeq": "11",
    "TranSeq": "11",
    "BranchId": "11",
    "TranTeller": "11",
    "AuthFlag": "1",
    "TranDate": "11",
    "TranTime": "143805927",
    "RetStatus": "S",
    "RetCode": "000000",
    "RetMsg": "交易成功",
    "PageTotalNum": "",
    "TotalNum": "",
    "PageStart": "",
    "PageEnd": "",
    "CurrentPageNum": ""
  }
```



2.验证码找回

服务器直接将验证码返回，例如某APP找回密码返回包。

```
HTTP/1.1 200 OK
Server: nginx/1.8.1
Date: Thu, 11 May 2017 02:11:04 GMT
Content-Type: text/html; charset=UTF-8
Connection: close
Vary: Accept-Encoding
Content-Language: zh-CN
Content-Length: 51

{"code": "1", "uid": "60570181", "verifycode": "762808"}
```

另外还有返回在Cookie中，例如

```
HTTP/1.1 200 OK
Server: nginx
Date: Tue, 08 Mar 2016 06:52:17 GMT
Content-Type: text/html; charset=GBK
Connection: keep-alive
Pragma: No-cache
Cache-Control: no-cache
Expires: Thu, 01 Jan 1970 00:00:00 GMT
Set-Cookie: will_cookie_phoneRandcode=341480; Domain=
Content-Length: 6239
```

另外还有可能在返回的页面源码中，需要注意提交的每一个参数。

3. 跳过验证步骤

输入重置账号后，跳过验证步骤，直接访问重置密码页面

然后提交找回申请，跳过选择找回方式。

直接访问 <http://uc.nearme.com.cn/usercenter/resetPassword.do>



nearME 个人中心

书籍 铃声 软件 游戏 主题 壁纸 音乐

密码找回：

1. 输入账号 2. 选择方式找回 3. 身份认证 4. 重置密码 5. 完成

我们收到你重置密码的请求，请在此处重新设置你的登录密码，完成操作后以新的密码登录。

新密码: *密码长度为6-16位数字或字母或字符组合

确认密码: *确认密码长度为6-16位数字或字母或字符组合

请输入新密码！

[返回登录 >](#)

安全提示：

1. 如果您的帐号设置过密保资料，密保用户可以通过同密保问题来设置新密码

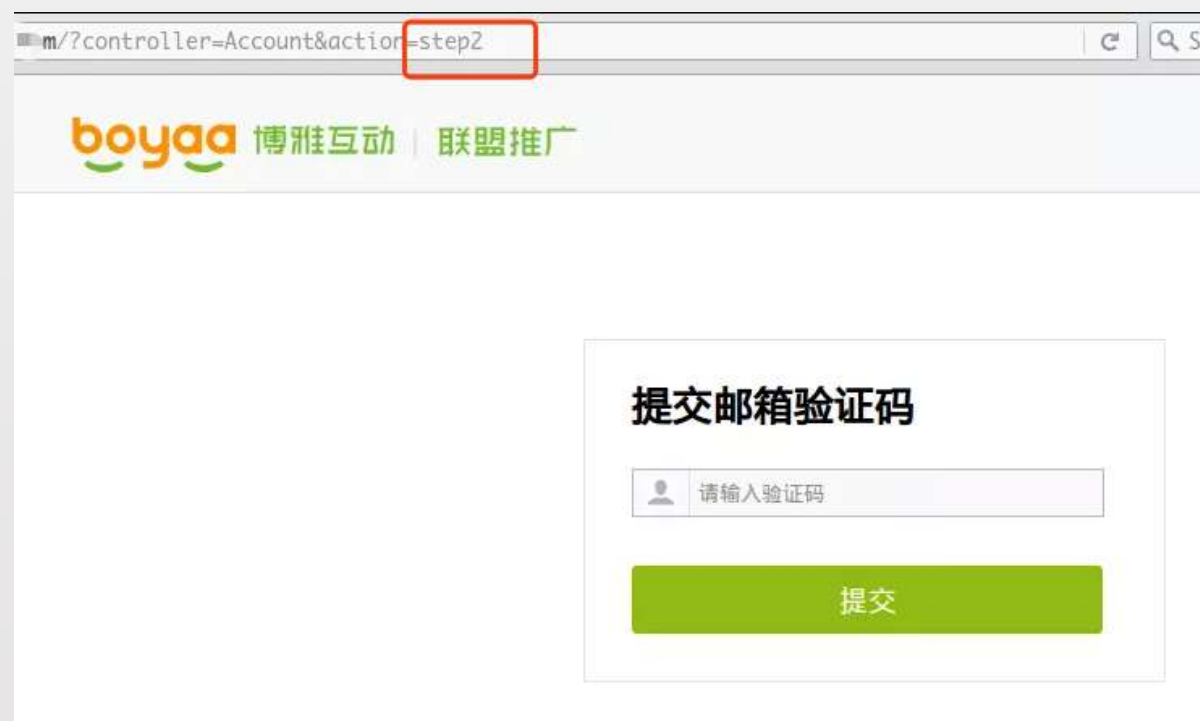
2. 无密保用户只有通过使用注册时填写的密码或者帐号由客服找回密码。

www.wooyun.org

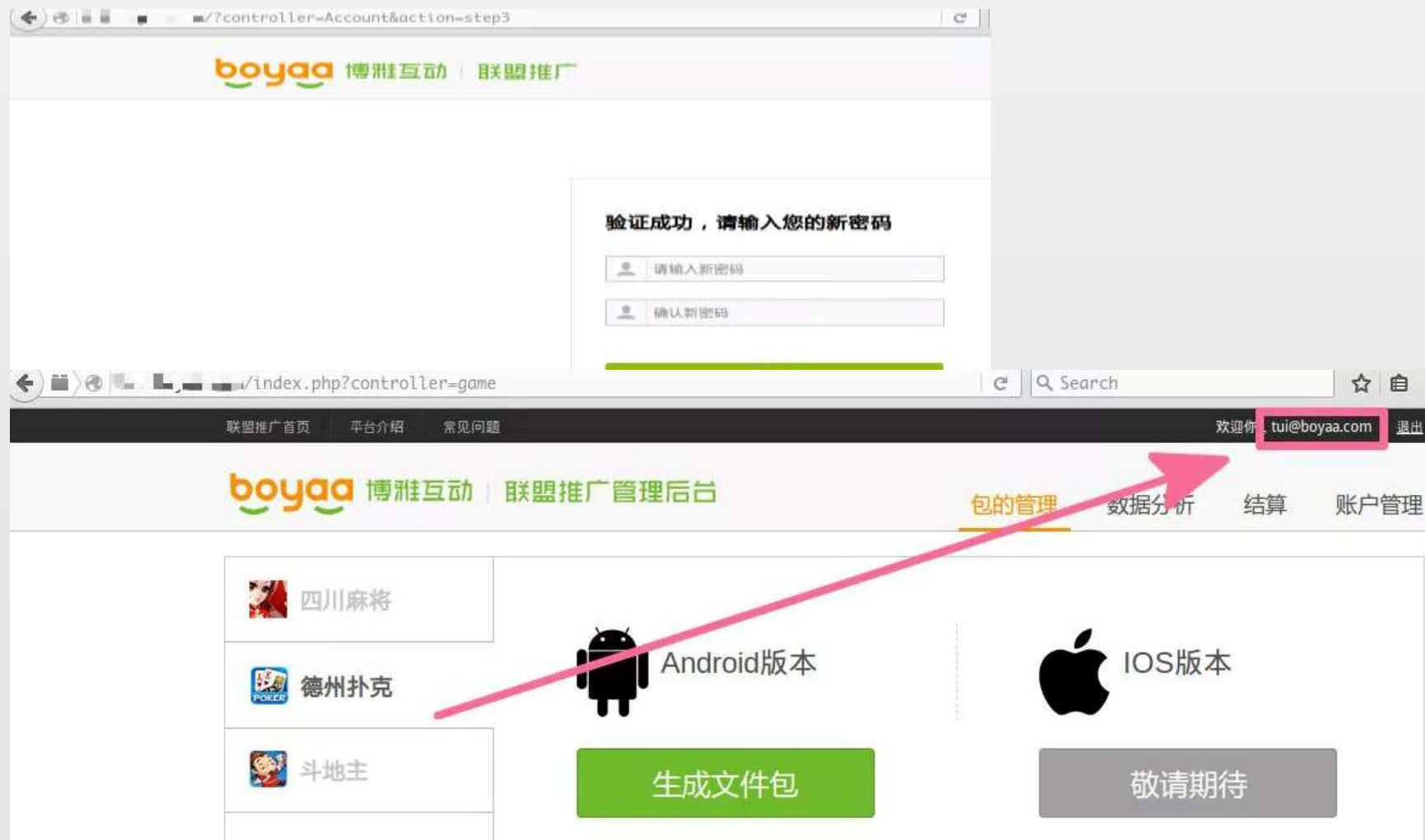
输入新密码，提示修改成功

3. 跳过验证步骤

这时不必输入验证码，直接将链接中的 step2 改为 step3



3. 跳过验证步骤



4.利用邮箱、手机号绑定

绑定用户邮箱的时候，可以通过修改uid将其他用户的邮箱绑定为自己的，从而任意重置用户密码。



4.利用邮箱、手机号绑定

https://[redacted]/findPwd/index

站点 新手上路 常用网址 JD 京东商城 jd

1

2

3

填写帐户名

验证身份

设置新密码

帐户名: [redacted]材VSP

验证码: r8vx| R8vX 看不清? 换一张!

下一步

4.利用邮箱、手机号绑定

https://[redacted]/findPwd/toValid

手上路 常用网址 JD 京东商城 jd

1 填写帐户名 2 验证身份 3 设置新密码 4 完成

请选择验证身份方式:

- 已验证手机
- ✓ 已验证邮箱

账号: 德*****P

已验证邮箱: 1*****@qq.com 若该邮箱已无法使用请联系客服

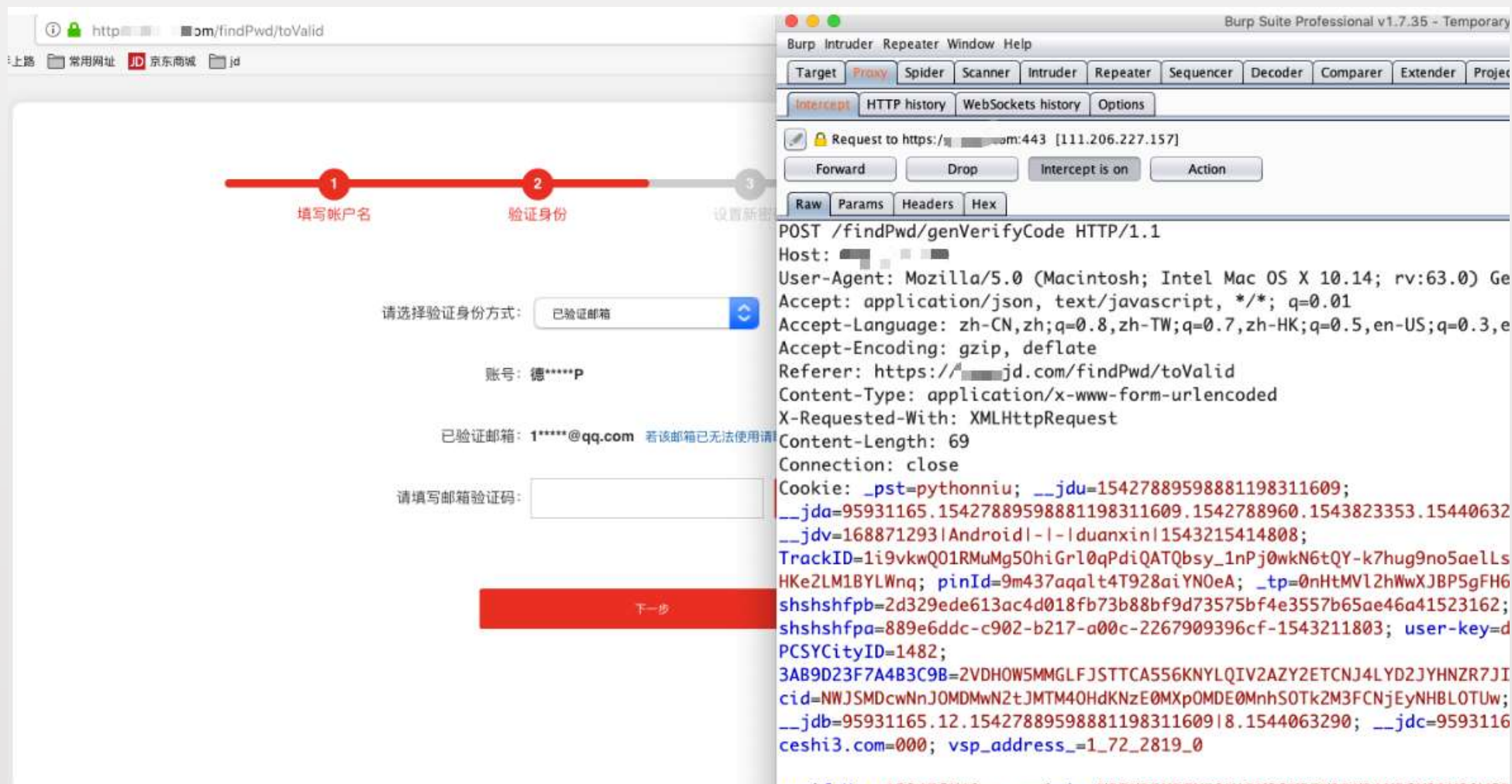
请填写邮箱验证码:

获取邮箱验证码

下一步

4. 利用邮箱、手机号绑定

修改他人凭证为自身可控凭证



The image shows a password recovery page on the left and a Burp Suite intercept window on the right.

Left Panel (Password Recovery Page):

- Progress bar: 1. 填写账户名 (Filled), 2. 验证身份 (Active), 3. 设置新密码 (Greyed out).
- Form fields: "请选择验证身份方式:" (Selected: 已验证邮箱), "账号: 德****P", "已验证邮箱: 1*****@qq.com", "请填写邮箱验证码:" (Empty).
- Button: "下一步" (Next Step).

Right Panel (Burp Suite Intercept):

- Request to: `https://[redacted].com:443 [111.206.227.157]`
- Method: `POST /findPwd/genVerifyCode HTTP/1.1`
- Host: `[redacted]`
- User-Agent: `Mozilla/5.0 (Macintosh; Intel Mac OS X 10.14; rv:63.0) Gecko/20100101 Firefox/63.0`
- Accept: `application/json, text/javascript, */*; q=0.01`
- Accept-Language: `zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2`
- Accept-Encoding: `gzip, deflate`
- Referer: `https://[redacted].jd.com/findPwd/toValid`
- Content-Type: `application/x-www-form-urlencoded`
- X-Requested-With: `XMLHttpRequest`
- Content-Length: `69`
- Connection: `close`
- Cookie: `__pst=pythonniu; __jdu=15427889598881198311609; __jda=95931165.15427889598881198311609.1542788960.1543823353.15440632; __jdv=168871293|Android|-|-|duanxin|1543215414808; TrackID=1i9vkwQ01RMuMg50hiGr10qPdiQATQbsy_1nPj0wkN6tQY-k7hug9no5aellS HKe2LM1BYLWnq; pinId=9m437aqalt4T928aiYN0eA; _tp=0nHtMVL2hWwXJBP5gFH6 shshshfpa=889e6ddc-c902-b217-a00c-2267909396cf-1543211803; user-key=d PCSYCityID=1482; 3AB9D23F7A4B3C9B=2VDH0W5MMGLFJSTTCA556KNYLQIV2AZY2ETCNJ4LYD2JYHNZR7JII cid=NWJSMDCwNnJOMDMwN2tJMTM40HdKNzE0MXpOMDE0MnhSOTk2M3FCNjEYnHBL0TUw; __jdb=95931165.12.15427889598881198311609|8.1544063290; __jdc=9593116 ceshi3.com=000; vsp_address_=1_72_2819_0`

4.利用邮箱、手机号绑定

京东慧采平台提醒您：请及时查看验证码，完成密码修改 ☆

发件人：京东JD.com <customer_service@jd.com> 

时间：2018年12月6日(星期四) 上午10:36

收件人：fu4k <1434559075@qq.com>



亲爱的VSP：

尊敬的用户，481534是您本次的身份验证码，30分钟内有效，请完成验证。工作人员绝不会向您索要此验证码，切勿告知他人。【】

Copyright © 2004-2018 京东JD.com



请选择验证身份方式： 已验证邮箱 

账号：德*****P

已验证邮箱：1*****@qq.com 若该邮箱已无法使用请

请填写邮箱验证码：

下一步

03 密码找回漏洞

4.利用邮箱、手机号绑定



1 填写帐户名

2 验证身份

3 设置新密码

4 完成

新登录密码:

确认新密码: 请再次输入密码

下一步



5. 第三方登录绑定其他用户

例如绑定微博账号的时候，先登录微博并且获取code，然后绑定code和UID的请求如下：

```
thirdPartyType=1&uid=60570181&state=test&code=fb3a6454736e15534486c5a214067943
```

通过修改uid可以将自己的微博绑定到其他用户账号，然后通过微博登录就可以登录任意用户账号。

03 密码找回漏洞

6. 没有验证验证码接收手机号是否与username或者session一致+

例如发送验证码的请求如下：

username=***&mobilePhone=***&randcodeAjax=6119

没有验证username是否和mobilePhone一致，通过修改mobilePhone为自己的手机号接受验证码。

找回密码

输入用户名

验证身份

重置密码

完成

验证方式： 手机验证

手机号码： 1305

获取短信验证码

短信验证码：

下一步

获取短信验证码接口，
将手机号换成自己的

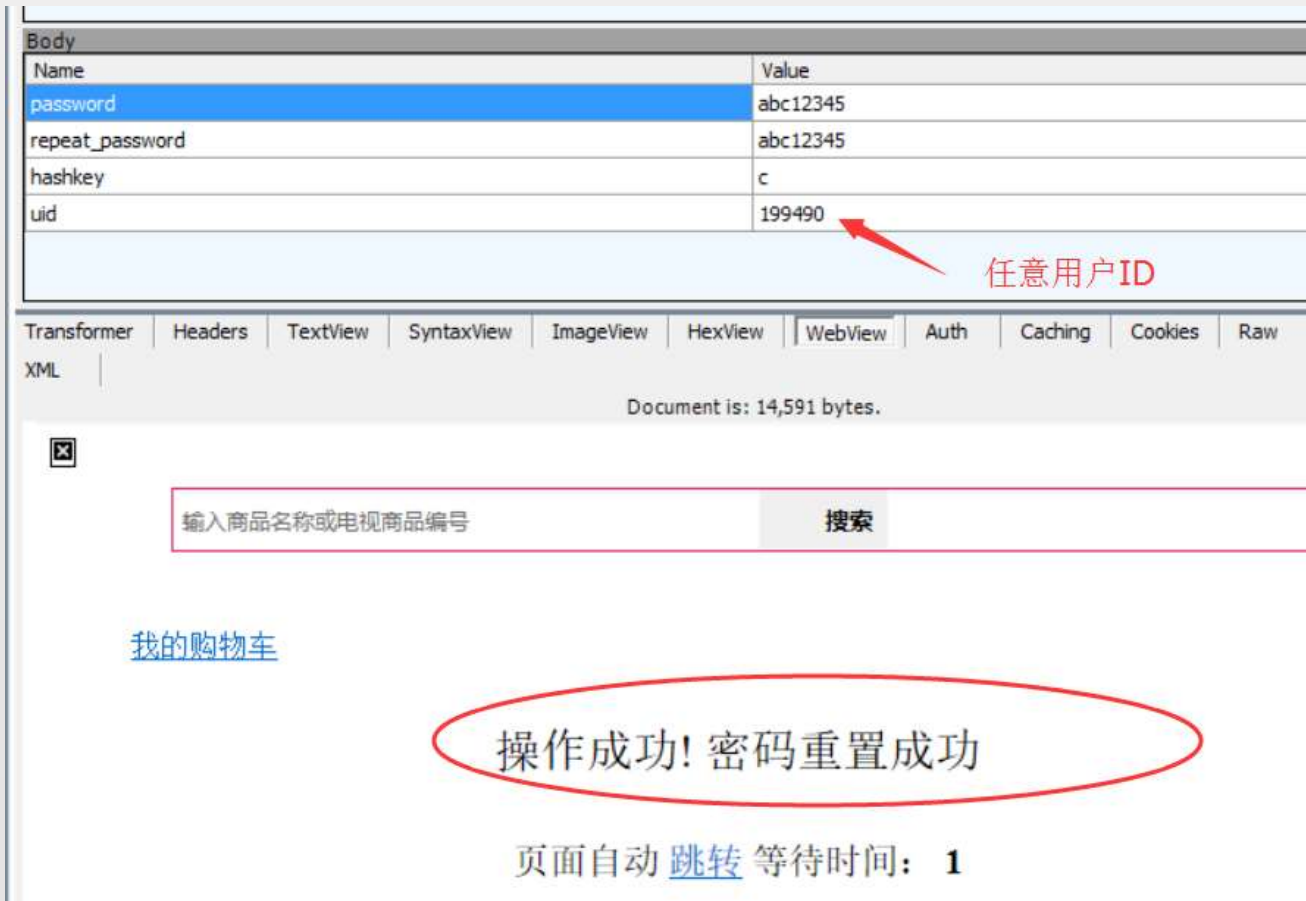
7.本地验证绕过

客户端在本地进行验证码是否正确的判断，而该判断结果也可以在本地修改，最终导致欺骗客户端，误以为我们已经输入了正确的验证码。

例如将返回包中的0修改为1即可绕过验证。

8.重置密码最后一步uid或者username可控

重置密码最后一步，重置账户通过用户传递的uid或者username控制，导致修改该UID即可重置其他用户密码。



The screenshot displays a web application interface. At the top, a table lists form fields: password, repeat_password, hashkey, and uid. The uid field contains the value 199490, which is highlighted with a red arrow and the text "任意用户ID". Below the table, there are tabs for Transformer, Headers, TextView, SyntaxView, ImageView, HexView, WebView, Auth, Caching, Cookies, and Raw. The XML tab is selected, showing a document of 14,591 bytes. Below the XML view, there is a search bar with the placeholder text "输入商品名称或电视商品编号" and a "搜索" button. Below the search bar, there is a link "我的购物车". At the bottom, a red oval highlights the text "操作成功! 密码重置成功". Below this, it says "页面自动 跳转 等待时间: 1".

Name	Value
password	abc12345
repeat_password	abc12345
hashkey	c
uid	199490

任意用户ID

Transformer Headers TextView SyntaxView ImageView HexView WebView Auth Caching Cookies Raw

XML

Document is: 14,591 bytes.

输入商品名称或电视商品编号 搜索

[我的购物车](#)

操作成功! 密码重置成功

页面自动 跳转 等待时间: 1

9.个人中心修改密码逻辑错误

当前密码的校验和修改新密码是单独分开的两个包。所以可以理解为没有校验当前密码。

修改密码的请求中如下：

```
ssoud=***&passwd=***
```

修改该ssoud即可。

原因：密码修改过程中没有校验当前密码，只需要通过修改ssoud（可能是用户标识）来更改密码，而不需要提供当前密码。

10.利用session重新绑定客户

重置密码最后一步是通过session获取用户名，然后再重置。

而用户名是在重置密码第一步时与session进行绑定，

那么如果重置密码的最后一步程序并没有验证该用户是够走完了验证流程，

那么就可以通过重新绑定session为其他账号从而达到任意密码重置目的。

11. 去掉验证参数绕过

邮件系统取回密码功能设计逻辑错误，存在认证绕过漏洞，
通过抓取数据包可通过修改报文，将找回问题答案参数删除后，直接进行对密码更改。

12.任意输入验证码修改用户密码

任意密码重置，随意输入验证码就可以修改别人用户的密码，就直接得到了其他用户的账号，危害十分巨大



修改密码

手机号: 13333333333

验证码: 123456 47秒后可再次发送

新密码:

确认新密码:

确定 取消



登录 注册

账号: admin

密码: 忘记密码?

登录

03 密码找回漏洞



12.任意输入验证码修改用户密码

任意密码重置，随意输入验证码就可以修改别人用户的密码，就直接得到了其他用户的账号，危害十分巨大

< 忘记密码	< 重置密码
① 为了保证您的账户安全，一天只能操作1次	① 密码必须包含字母、数字至少两种组合，且密码长度不小于6
手机号 18075714593	新密码 请输入6-16位数字或者字母
短信验证码 1234 55s后	确认密码 请再次输入新密码
下一步	完成

附录一：互联网行业-业务逻辑漏洞

通用业务模块	业务逻辑漏洞
登录	暴力破解用户名密码 撞库 验证码爆破和绕过 手机号撞库 账户权限绕过
注册	恶意用户批量注册 恶意验证注册账户 存储型XSS
密码找回	重置任意用户账户密码 批量重置用户密码 新密码劫持 短信验证码劫持 用户邮箱劫持篡改
后台管理	管理员用户名密码绕过 目录遍历
会员系统	用户越权访问 个人资料信息泄漏 个人资料遍历
传输过程	COOKIE注入 COOKIE跨站 COOKIE劫持 明文传输
评论	POST注入 CSRF 存储型XSS 遍历用户名

附录二：P2P金融行业-业务逻辑漏洞

通用业务模块	业务逻辑漏洞
登录	暴力破解用户名密码 撞库 验证码爆破和绕过 手机号撞库 账户权限绕过
注册	恶意用户批量注册 恶意验证注册账户 存储型XSS
密码找回	重置任意用户账户密码 批量重置用户密码 新密码劫持 短信验证码劫持 用户邮箱劫持篡改
购买支付	商品金额篡改 商品数量篡改 交易信息泄漏
充值	虚假充值金额 充值数量篡改 篡改充值账户
抽奖/活动	刷取活动奖品 盗刷积分 抽奖作弊

代金券/优惠券	批量刷取代金券/优惠券 更改代金券金额 更改优惠券数量
订单	订单信息泄漏 用户信息泄漏 订单遍历 合同遍历 银行卡信息遍历
账户	账户绕过 账户余额盗取 账户绑定手机号绕过
会员系统	用户越权访问 个人资料信息泄漏 个人资料遍历
传输过程	COOKIE注入 COOKIE跨站 COOKIE劫持 明文传输
评论	POST注入 CSRF 存储型XSS 遍历用户名

附录三：电商行业-业务逻辑漏洞

通用业务模块	业务逻辑漏洞
登陆	暴力破解用户名密码 撞库 验证码爆破和绕过 手机号撞库 账户权限绕过
注册	恶意用户批量注册 恶意验证注册账户 存储型XSS
密码找回	重置任意用户账户密码 批量重置用户密码 新密码劫持 短信验证码劫持 用户邮箱劫持篡改
购买支付	商品金额篡改 商品数量篡改 交易信息泄漏
抽奖/活动	刷取活动奖品 盗刷积分 抽奖作弊
代金券/优惠券	批量刷取代金券/优惠券 更改代金券金额 更改优惠券数量

订单	订单信息泄漏 用户信息泄漏 订单遍历 收货地址遍历
账户	账户绕过 账户余额盗取 账户绑定手机号绕过
抢购活动	低价抢购 抢购作弊 刷单
运费	运费绕过
会员系统	用户越权访问 个人资料信息泄漏 个人资料遍历
传输过程	COOKIE注入 COOKIE跨站 COOKIE劫持 明文传输
评论	POST注入 CSRF 存储型XSS 遍历用户名
第三方商家	盗号 商家账户遍历 越权访问其他商家用户

附录四：政务行业-业务逻辑漏洞

通用业务模块	业务逻辑漏洞
登录	暴力破解用户名密码 撞库 验证码爆破和绕过 手机号撞库 账户权限绕过
注册	恶意用户批量注册 恶意验证注册账户 存储型XSS
密码找回	重置任意用户账户密码 批量重置用户密码 新密码劫持 短信验证码劫持 用户邮箱劫持篡改
后台管理	管理员用户名密码绕过 目录遍历
业务查询	恶意查询 办理人信息泄漏
业务办理	顶替办理 绕过业务流程办理 篡改其他办理人信息 办理人信息泄漏
传输过程	COOKIE注入 COOKIE跨站 COOKIE劫持 明文传输
评论	POST注入 CSRF 存储型XSS 遍历用户名

总结

- 1、测试业务的时候，了解清楚业务的整体流程，可以利用思维导图快速清理各个业务之间的关系
- 2、重点关注的业务:个人（他人）信息、密码修改（找回）、支付流程、注册流程、需要手机、邮箱验证的业务。
- 3、对每个业务模块进行抓包，分析其中各种请求，注意`特殊参数`，很有可能就是这些特殊参数`决定了业务步骤。
- 4、抓包重放的过程需要多次实验，判断是否可以跳过（绕过），如何跳过（绕过），纯数字可以用`数字 + 字母`尝试绕过
- 5、返回包中数据的分析~关注特殊字符串和特殊参数，还有JS文件（'JS中可能会存在信息泄漏'）。
- 6、综上所述，业务流程需同时结合'HTTP/HTTPS'请求分析，重点可以关注那些具有代表性的参数，绕过必要验证，跳过业务步骤。

04

用户输入合规性



 用户输入合规性原理

用户输入合规性原理是确保用户提供的数据符合应用程序或系统的预期规则、约定或标准。这是确保应用程序功能正常、数据完整性、安全性和可用性的关键方面。

 利用场景

1. 表单验证
2. 支付信息
3. 身份验证
4. 数据过滤
5. 搜索引擎查询
6. 评论和反馈
7. 电话号码验证
8. 电子邮件验证

简单的来说只要有输入的地方就需要遵循用户输入合规性

 用户输入合规性测试

1.注入测试（不详细讲解）

2. XSS测试（不详细讲解）

3.数据极端情况测试

 1.数据极端情况测试

1、超长字符串。

输入超长字符串可能会导致系统拒绝服务或绕过某些限制。

2、特殊符号。

曾经遇到过一个案例，密码框输入><就可以登录任意用户账号。

3、整数溢出。

利用整数溢出，精度丢失等，可能导致支付漏洞。

1. 墨者靶场登录密码重置漏洞分析溯源关卡

注册后访问

<https://www.mozhe.cn/bug/detail/K2sxTTVYaWNncUE1cTdyNXIyTkIHdz09bW96aGUmozhe>

2. 根据今日所学知识在zzcms靶场挖洞，并写出漏洞报告



感谢您的观看

THANKS FOR YOUR WATCHING